

SECUREPR

Reusable Pull Request Security Harness and Security Gate

Marco Ponce

Seton Hall University

M.S. Cybersecurity

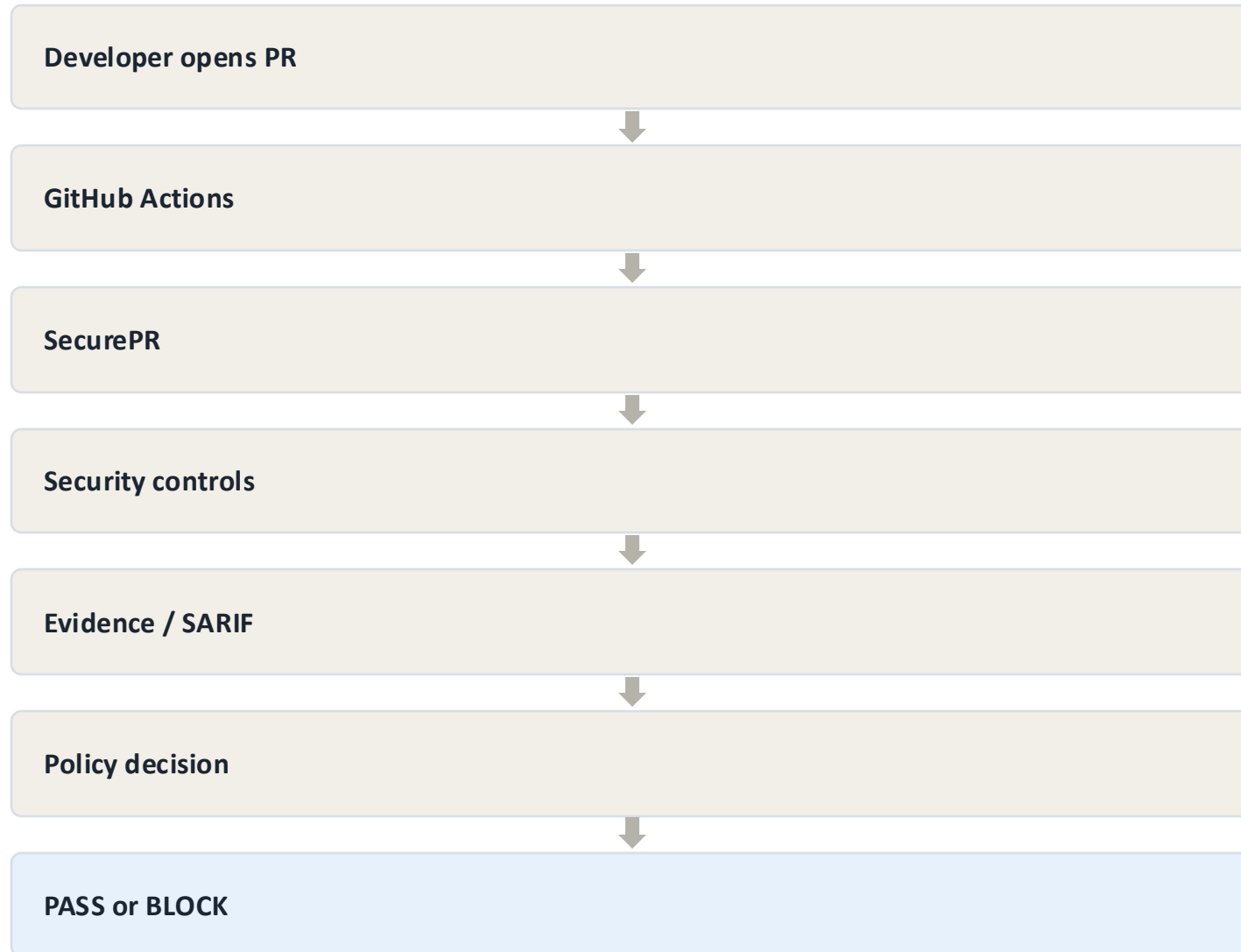
ISCI 6201: Secure Software Development

Problem and motivation

- Pull-request security checks are often spread across multiple disconnected tools
- Developers need one consistent security gate applied to every PR
- SecurePR combines several automated security controls into a reusable GitHub Actions workflow
- The system produces evidence and a final PASS / BLOCK decision

PASS does not mean the repository is completely secure. Human review is still required

SecurePR workflow



Key points

- The workflow is reusable across repositories
- Security-sensitive workflow reuse can be pinned to a reviewed commit SHA, rather than a mutable tag or branch

Security controls

Repository

- Repository profiling
- Tests
- Dependency auditing

Secrets & Code

- Gitleaks
- Semgrep custom rules
- CodeQL

Evidence & Policy

- SARIF aggregation
- OWASP Top 10:2025 mapping
- PASS / BLOCK decision

Custom Semgrep rules and OWASP mapping

Custom rules

- Hardcoded passwords / credentials
- Python hardcoded credential assignments
- Privileged usernames
- Unsafe eval() / exec()
- Disabled TLS verification in Python

OWASP mappings

Hardcoded password	A04, A07
Python hardcoded credential	A04, A07
Privileged username	A01, A07
Unsafe eval / exec	A05
Unverified TLS	A02, A04

A Python AST-based rule was added after a benchmark case was not reliably caught by the original generic rule

PASS / BLOCK demonstration

1

Clean PR

No required automated finding

PASS

2

Synthetic hardcoded credential

Credential detected

BLOCK

3

Remediated PR

Credential removed, workflow reruns

PASS

Benchmark results

37 reviewed cases

	Predicted BLOCK	Predicted PASS
Actual finding	TP = 15	FN = 6
Actual clean	FP = 0	TN = 16

83.78%

Accuracy

100%

Precision

71.43%

Recall

83.33%

F1

These results are only from the reviewed 37-case benchmark. They should not be generalized to all repositories or all possible vulnerabilities

Limitations, future work, and takeaway

Limitations

- Benchmark coverage is limited
- False negatives remain
- PASS only means configured automated controls found no condition requiring a block

Future work

- Broader benchmarks
- More security rules
- Additional security controls
- Expanded validation

SecurePR turns multiple pull-request security checks into one reusable, policy-driven security gate